

Étude des services ISO 27002

Sécurité des Systèmes d'Information

Paul VEROT, 20212888

Master 2 CNS-SR, 2026



UNIVERSITÉ ÉVRY
PARIS-SACLAY



UNIVERSITÉ ÉVRY
PARIS-SACLAY

Département d'informatique
univ-evry.fr

Titre:

Étude des services ISO 27002

Thème:

Sécurité des Systèmes d'Information

Groupe:

Master 2 CNS-SR

Participants:

Paul VEROT, 20212888

Email:

pauljeanlouisverot@protonmail.com
20212888@etud.univ-evry.fr

Superviseur:

Damien PLOIX

Nombre de pages:

13

Dernier changement:

08-09-2026

Résumé:

--

Contexte :

L'entreprise SimBuild est spécialisée dans la production de cartes SIM pour différents opérateurs téléphoniques. Elle s'est faite dérober les certificats privés de cryptage de ses cartes par une agence d'espionnage d'un grand pays. Ceci a permis à ce pays de récupérer des informations sur toutes les communications passées par des téléphones portables utilisant ces cartes SIM.

L'entreprise est structurée en deux parties. La première gère les processus transverses (finance, RH, achat, ...) et la seconde la production des cartes SIM. Cette dernière activité est organisée autour de deux processus principaux : l'un relatif à la chaîne de production des cartes SIM physiques et le second visant à y inscrire les informations sensibles (numéros, certificats).

Le processus d'inscription des données sensibles se décompose en trois activités principales :

- déterminer l'opérateur cible des cartes SIM traitées, via une application hébergée en data-centre et accédée via un client léger,
- préparer les éléments de sécurité des cartes SIM, via une application installée sur les postes de travail des opérateurs et qui utilise des informations présentes sur les serveurs bureautiques de l'entreprise,
- la combinaison des deux précédentes étapes pour inscrire les informations sur les cartes SIM via l'utilisation d'un client lourd relié à la base de données de l'application et aux serveurs bureautiques.

Exercice : Proposez des schémas d'attaque "kill chain" ou MITRE ATT&CK ayant permis la réalisation de l'attaque. Expliquez si les services ISO 27002 étudiés en cours auraient permis (ou pas) de protéger l'entreprise.

Partie 1 - Vecteurs d'attaque envisageables

Reconnaissance

La distribution et le contrôle de carte SIM étant primordial pour la telecom d'un pays ou d'une région, et étant donnée l'omnipresence d'appareils cellulaires sur un territoire donné ; la prise de contrôle de la ligne de production peut être très avantageuse à des fins lucratives ou de renseignement.

Vecteurs plausibles

Plusieurs vecteurs d'attaque sont envisageable :

- Phishing → un des employés avec permission sur le système s'est fait compromettre
- Vulnérabilité → une des machines sur le réseau était mal sécurisée (ex: ssh par mdp, vulnérabilité software 0day ou non mitigée ; cf. npm,)
- Inside-Job → un des employés a volontairement introduit un logiciel malicieux
- Intrusion physique → un acteur malveillant a pu avoir accès physiquement au système (faille de sécurité sur site)
- Cheval de Troie → un appareil compromis a pu être distribué ou laissé près des lieux (ex: clé USB sur le parking, disque vérolé dans la supply-chain)

Précédents historiques

Phishing - Gemalto (2011)

Le cas d'étude est similaire au piratage de l'entreprise GEMALTO en 2011. Où deux agences gouvernementales, la National Security Agency (EUA) et le Government Communications Headquarters (UK), se sont introduits dans les systèmes de l'entreprise Gemalto, fabricant des cartes SIM fournissant plus de 450 opérateurs telecoms dans le monde. Les attaquants avaient pour but de saisir les clés de chiffrement afin de pouvoir plus facilement espionner les échanges entre utilisateurs sur les réseaux cellulaires supposément.

With these stolen encryption keys, intelligence agencies can monitor mobile communications without seeking or receiving approval from telecom companies and foreign governments.

— Gemalto presents the findings of its investigations into the alleged hacking [1]

Un rapport publié par Thalès décrit :

In July 2010, a second incident was identified [...]. This involved fake emails sent to one of our mobile operator customers spoofing legitimate Gemalto email addresses. The fake emails contained an attachment that could download malicious code. We immediately informed the customer and also notified the relevant authorities both of the incident itself and the type of malware used. During the same period, we also detected several attempts to access the PCs of Gemalto employees who had regular contact with customers.

— Gemalto presents the findings of its investigations into the alleged hacking [1]

La seconde partie semble indiquer que les attaquants aient eut un certain accès physique aux machines de l'entreprise. Cependant, ces machines n'étaient pas responsables des clefs de chiffrement et ne permettaient pas l'accès aux réseaux sur lesquels ces machines se trouvaient.

Les documents Snowden publiés par *The Intercept* vont plus loin que la version officielle de Gemalto : dès 2010, la NSA et le GCHQ avaient formé une unité dédiée, la **Mobile Handset Exploitation Team**, et repéré leurs cibles via X-KEYSCORE en épluchant les emails des employés [2].

[“we”] believe we have their entire network

— GCHQ slide, via The Intercept [2]

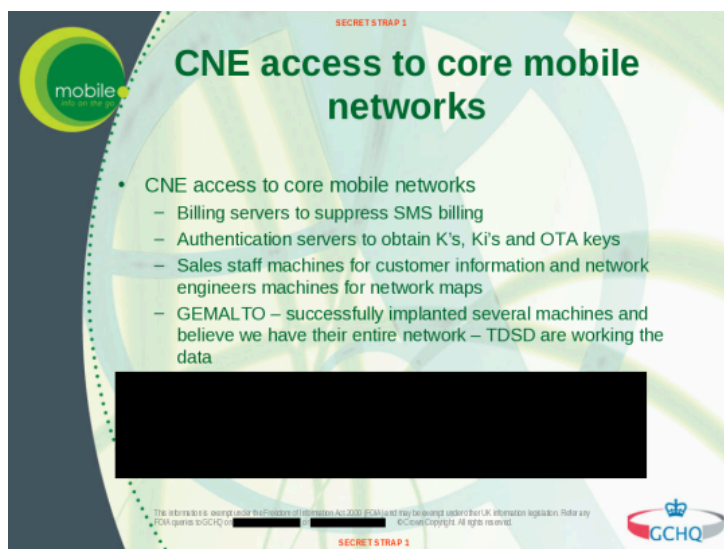


Figure 1:

La slide confidentielle du GCHQ mentionne également que les deux agences aient accès aux serveurs de paiement, aux serveurs de clef OTA et aux machines POS.

GCHQ also claimed the ability to manipulate the billing servers of cell companies to “suppress” charges in an effort to conceal the spy agency’s secret actions against an individual’s phone.

— The Intercept [2]

le journal *The Intercept* a publié un article très complet sur le sujet, d'où je tire une grande partie des informations de cette section.

Belgacom (GCHQ, 2013) même unité, même méthode : de faux profils LinkedIn (*Quantum Insert*) ont piégé des ingénieurs réseau pour atteindre directement les routeurs gérant le trafic international, sans

passer par le réseau bureautique [3], [4].

Supply-chain - dépendances orphelines et paquets vérolés

Dans une *supply chain attack*, un composant logiciel ou matériel est compromis avant d'arriver dans les systèmes. On peut imaginer qu'une dépendance logiciel orphannée ait été employée par les attaquants, comme dans les attaques sur le *Arch Linux User Repository* en 2026, où des paquets orphannés avaient été adoptés par des acteurs malveillants afin de s'y intégrer des *info-stealer*.

On peut également imaginer qu'une dépendance pour une ancienne version d'un Moteur de Base de Données ait été utilisée (eg. MongoDB vers.1). Ce paquet vérolé, si intégré dans un dépôt de paquet (ie. rpm-fusion, terra, cid) aurait pu être installé avec une simple mise à jour du système.

Cheval de Troie - Stuxnet

Une autre instance autement médiatisée est le piratage (Stuxnet) par les États-Unis d'Amérique et Israël d'une centrifugeuse à matériaux radioactif en Iran. Le vecteur d'attaque étant une clef USB laissée sur le parking de l'usine. Comptant sur le fait qu'un employé la ramasse et s'en serve sur son poste de travail.[5]

Stuxnet attacked Windows systems using an unprecedented four zero-day attacks [...]. It is initially spread using infected removable drives such as USB flash drives, which contain Windows shortcut files to initiate executable code.

— Wikipedia [5]

Vulnérabilité - services exposés sur le réseau

Le système aurait pu être visé si par exemple une interface web comme cockpit ou arrangoWebUI avait été exposée au web. Un moteur de recherche comme Shodan permet d'identifier des machines sur le web (par exemple avec les favico qui possèdent un hash unique). Une analyse avec nmap pourrait révéler des ports exposés, et ainsi donner des indices sur le type de moteur de bases de données (27017 → mongodb, 51413 → arrangodb, 5985 → couchdb). Une analyse plus poussée sur ces ports permet dans certains cas d'obtenir des informations cruciales sur l'état du moteur de BDD. Par exemple, Microsoft SQL envoya le numéro de build avec un handshake TDS, et dans certains cas une liste complète des instances installées avec leurs ports respectifs. Une fois la version du logiciel connue, elle peut être cross-référencée avec des bases de données de vulnérabilité (CVE).

Par exemple en 2017 sur PostgreSQL avec :

PostgreSQL versions before 9.2.22, 9.3.18, 9.4.13, 9.5.8 and 9.6.4 are vulnerable to incorrect authentication flaw allowing remote attackers to gain access to database accounts with an empty password.

— CVE-2017-7546 [6]

Partie 2 - 2 hypothèses différents

Déroulé 1 - attaque réussie

Reconnaissance, Weaponizing & Delivery

On retient ici l'hypothèse phishing, cohérente avec le précédent Gemalto détaillé en Partie 1 : un employé du réseau bureautique de SimBuild est compromis via une pièce jointe piégée.

Exploitation

Contrairement au cas réel de Gemalto, l'application de préparation des éléments de sécurité et le client lourd relié à la base de données ne sont pas isolés du réseau bureautique compromis → l'attaquant peut donc progresser au-delà du seul réseau bureautique.

Installation

Pour exfiltrer des clés sur plusieurs lots de cartes SIM, l'attaquant doit maintenir un accès dans la durée, par exemple au niveau du client lourd relié à la base de données et aux serveurs bureautiques. Le cas SUNBURST (SolarWinds, 2020) illustre une installation particulièrement furtive : le backdoor était injecté dans une DLL signée du logiciel légitime, lui permettant de survivre aux mises à jour [7]. Ces DLL frauduleux avaient pu être signés grâce aux clés volées.

Command & Control

Le canal de contrôle doit rester discret pour échapper à une éventuelle supervision réseau. SUNBURST encodait ses communications dans des requêtes DNS imitant la télémétrie légitime de SolarWinds, avec des délais volontairement irréguliers pour déjouer l'analyse comportementale [8].

Action on Objective

Cette dernière étape correspond à l'objet même du cas d'étude : l'exfiltration des certificats privés de chiffrement des cartes SIM, déjà illustrée par le cas Gemalto cité plus haut → les clés dérobées permettent d'intercepter le trafic mobile sans coopération des opérateurs [1].

Déroulé 2 - défense réussie

Reconnaissance, Weaponizing & Delivery

Le vecteur initial est identique à la Partie 2 : le phishing réussit et l'attaquant obtient un accès au réseau bureautique de SimBuild.

Exploitation

Dans le cas de Gemalto, les attaquants n'ont pas pu accéder aux systèmes critiques. Ce dû à leur architecture réseau :

These intrusions only affected the outer parts of our networks – our office networks - which are in contact with the outside world. The SIM encryption keys and other customer data in general, are not stored on these networks. It is important to understand that our network architecture is designed like a cross between an onion and an orange; it has multiple layers and segments which help to cluster and isolate data.

— Gemalto presents the findings of its investigations into the alleged hacking [1]

Considérant que les systèmes de SimBuild sont segmenté de manière analogue à Gemalto, il est raisonnable de penser qu'une attaque similaire aurait les mêmes effets → l'attaquant reste cantonné au réseau bureautique.

Installation

Sans accès aux machines portant les clefs de chiffrement, l'installation complète, conforme au plan (Reconnaissance) n'est pas possible. Cependant, il est toujours possible que les attaquants décident d'un nouvel objectif avec les machines déjà compromises (parc RH, Marketing, Administration, ...). Bien que moins sévère que les serveurs portant les clefs, une paralysie des machines peut entraîner de sérieux ralentissements, et dans l'éventualité où des bases de données ou stockage de masse aient été compromis, les attaquants pourraient se rabattre sur un chiffrement des données.

Command & Control et Action on Objective

N'ayant pu obtenir les clefs, ces parties ne peuvent plus se jouer.

Partie 3 - Normes ISO 27001/2

La norme ISO/IEC 27002 est un document qui détaille les pratiques de sécurité des systèmes d'information. Publiée par ISO, l'Organisation Internationale de Standardisation, son but est de définir un standard que toutes les entreprises peuvent suivre afin d'uniformiser les notions de sécurité informatique (dans le cas de 27001/2, ISO publie d'autres documents de standardisation dans tous les domaines industriels).

La norme ISO 27002 contient des recommandations quant aux vecteurs d'attaque mentionnés plus haut.

Phishing

6.3 The organization should identify, prepare and implement an appropriate training plan for technical teams whose roles require specific skill sets and expertise. Technical teams should have the skills for configuring and maintaining the required security level for devices, systems, applications and services. If there are missing skills, the organization should take action and acquire them.

8.5 Secure authentication technologies and procedures should be implemented based on information access restrictions and the topic-specific policy on access control. [...] To ensure a user or an entity is securely authenticated, when access to systems, applications and services is granted.

— ISO/IEC:27002 [9]

Ces deux passages décrivent l'importance de former le personnel et de garder une liste d'accès restreinte pour limiter le rayon d'action d'un attaquant.

Le cas Belgacom (cf. Partie 1) montre cependant une limite de ces deux points : l'ingénieur visé n'a commis aucune erreur, la fausse page LinkedIn interceptait sa connexion au niveau réseau (*Quantum Insert*) sans dépendre d'une action risquée de sa part. Formation (6.3) et authentification (8.5) ne suffisent donc pas seules face à ce type d'attaque ; il faudrait également surveiller/valider le trafic réseau sortant (cf. 8.20).

8.20 Networks and network devices should be secured, managed and controlled to protect information in systems and applications. [...] To protect information in networks and its supporting information processing facilities from compromise via the network.

— ISO/IEC:27002 [9]

Vulnérabilité (CVE non patché)

8.8 Information about technical vulnerabilities of information systems in use should be obtained, the organization's exposure to such vulnerabilities should be evaluated and appropriate measures should be taken.

— ISO/IEC:27002 [9]

Inside-Job

5.15 *Rules to control physical and logical access to information and other associated assets should be established and implemented based on business and information security requirements.*

Purpose

To ensure authorized access and to prevent unauthorized access to information and other associated assets.

Guidance

Owners of information and other associated assets should determine information security and business requirements related to access control. A topic-specific policy on access control should be defined which takes account of these requirements and should be communicated to all relevant interested parties. These requirements and the topic-specific policy should consider the following: a) determining which entities require which type of access to the information and other associated assets; c) physical access, which needs to be supported by appropriate physical entry controls (see 7.2, 7.3, 7.4); e) restrictions to privileged access (see 8.2); [...] d) information dissemination and authorization (e.g. the need-to-know principle) and information security levels and classification of information (see 5.10, 5.12, 5.13); f) segregation of duties (see 5.3); [...] i) formal authorization of access requests (see 5.16 and 5.18); the management of access right

— ISO/IEC:27002 [9]

Ce passage souligne l'importance de liste de contrôle d'accès pour les personnels de l'entreprise. Il est également souligné l'importance de la ségrégation/séparation des tâches et des accès aux information (*need to know basis* et *security by obscurity*).

Un autre passage intéressant sur le sujet est le point **6.4** qui mentionne les processus disciplinaire en cas de tort.

6.4 *A disciplinary process should be formalized and communicated to take actions against personnel and other relevant interested parties who have committed an information security policy violation. Purpose To ensure personnel and other relevant interested parties understand the consequences of information security policy violation, to deter and appropriately deal with personnel and other relevant interested parties who committed the violation.*

— ISO/IEC:27002 [9]

Intrusion physique

7 *Security perimeters should be defined and used to protect areas that contain information and other associated assets. Purpose To prevent unauthorized physical access, damage and interference to the organization's information and other associated assets.*

— ISO/IEC:27002 [9]

Le chapitre 7 entier est dédié à la sécurité physique et définit les recommandations quant aux points d'accès, visiteurs, livraisons, systèmes de surveillance, etc.

Cheval de Troie

7.10 Storage media should be managed through their life cycle of acquisition, use, transportation and disposal in accordance with the organization's classification scheme and handling requirements. [...] To ensure only authorized disclosure, modification, removal or destruction of information on storage media.

— ISO/IEC:27002 [9]

Le point **7.10** mentionne spécifiquement les supports de stockages comme les clefs USB. Le passage indique que les médias amovibles devraient être gérés dans leur cycle de vie entier par l'entreprise pour réduire le risque d'interférence externe. Point qui est rejoint par le chapitre **8.7** qui mentionne la protection contre les virus, les médias amovibles étant un vecteur conséquent.

Supply chain

— ISO/IEC:27002 [9]

Les chapitres **5.19** à **5.22** mentionnent la sécurité liée aux fournisseurs logiciels et les pratiques quant au monitoring de ces derniers ainsi que les contrats relevant du maintien et de la sécurité par les fournisseurs.

Partie 4 - Cartographie MITRE ATT&CK

La Cartographie MITRE ATT&CK présente une plus grande granularité par rapport au **kill-chain** de Lockheed-Martin.

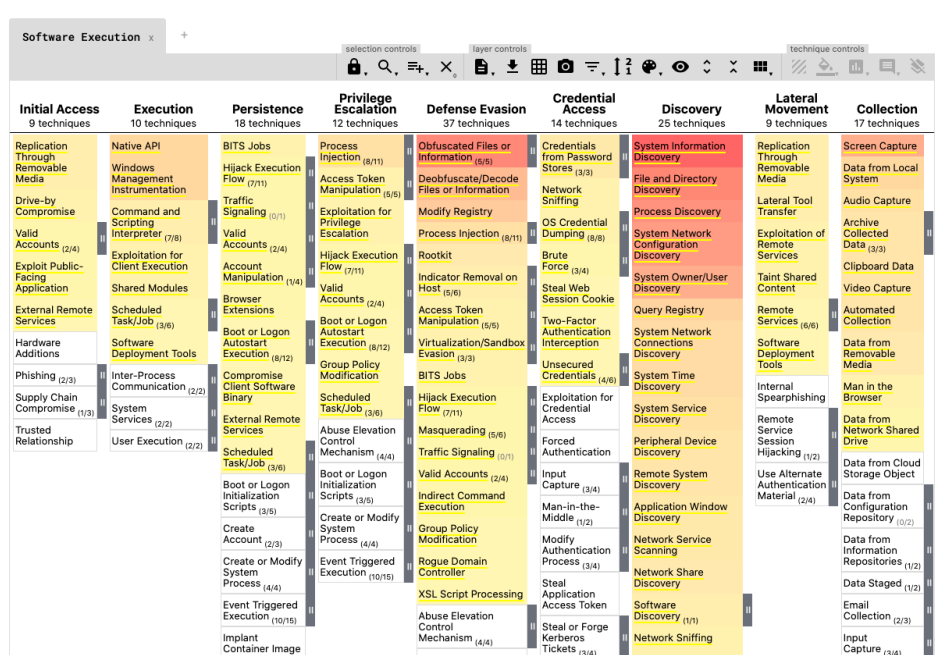


Figure 2: Matrice ATT&CK

Reconnaissance

Le ciblage de SimBuild correspond à la technique T1591 (Gather Victim Org Information) ; le repérage de services exposés via Shodan/nmap (cf. Partie 1) correspond à T1596.005 (Search Open Technical Databases: Scan Databases), ce qui peut se mitiger par une segmentation du réseau (M1030) comme mentionné plus haut dans le rapport *Thalès* avec l'analogie de l'oignon et de l'orange.

Initial Access

Selon le vecteur retenu en Partie 1, plusieurs techniques peuvent s'appliquer : le phishing de Gemalto correspond à T1566.001 (Spearphishing Attachment), la dépendance vérolée de l'AUR/MongoDB à T1195.001 (Compromise Software Dependencies), la clef USB de Stuxnet à T1091 (Replication Through Removable Media), et l'interface web exposée avec la CVE PostgreSQL à T1190 (Exploit Public-Facing Application).

Execution

L'ouverture de la pièce jointe piégée par l'employé correspond à T1204.002 (User Execution: Malicious File).

Persistence

L'installation d'une porte dérobée dans une DLL signée, à l'image de SUNBURST, correspond à T1554 (Compromise Host Software Binary).

Command & Control

Le canal DNS de SUNBURST correspond à T1071.004 (Application Layer Protocol: DNS) serait détectable par une inspection réseau (M1031).

Collection & Exfiltration

La récupération des clefs privées correspond à T1552.004 (Unsecured Credentials: Private Keys).

References

- [1] Thales, “Gemalto presents the findings of its investigations into the alleged hacking of SIM card encryption keys by Britain's Government Communications Headquarters (GCHQ) and the U.S. National Security Agency (NSA) | Thales Group.” 2015.
- [2] J. Scahill and J. Begley, “The Great SIM Heist: How Spies Stole the Keys to the Encryption Castle.” 2015.
- [3] R. Gallagher, “Operation Socialist: How GCHQ Spies Hacked Belgium's Largest Telco.” Dec. 2014.
- [4] Wikipedia contributors, “Operation Socialist — Wikipedia, The Free Encyclopedia.” [Online]. Available: https://en.wikipedia.org/w/index.php?title=Operation_Socialist&oldid=1359622831
- [5] Wikipedia contributors, “Stuxnet — Wikipedia, The Free Encyclopedia.” [Online]. Available: <https://en.wikipedia.org/w/index.php?title=Stuxnet&oldid=1373234009>
- [6] “CVE-2017-7546 : PostgreSQL versions before 9.2.22, 9.3.18, 9.4.13, 9.5.8 and 9.6.4 are vulnerable.”
- [7] “Advanced Persistent Threat Compromise of Government Agencies, Critical Infrastructure, and Private Sector Organizations (AA20-352A).” 2020.
- [8] “Sunburst: connecting the dots in the DNS requests.” 2021.
- [9] “Information security, cybersecurity and privacy protection — Information security controls.” [Online]. Available: <https://www.iso.org/standard/75652.html>